

Antônio Palmeira de Araújo Neto

Gestão de riscos em **ambientes de TI**

Dados Internacionais de Catalogação na Publicação (CIP)
(Claudia Santos Costa – CRB 8ª/9050)

Araújo Neto, Antônio Palmeira de
Gestão de riscos em ambientes de TI / Antônio Palmeira de Araújo
Neto. – São Paulo : Editora Senac São Paulo, 2025. – (Série Universitária)

Bibliografia.
e-ISBN 978-85-396-5778-0 (ePub/2025)
e-ISBN 978-85-396-5779-7 (PDF/2025)

1. Tecnologia da informação – Gestão de riscos. I. Título. II. Série.

25-2564c

CDD-005.8

658.47

BISAC COM053000

COM032000

Índices para catálogo sistemático:

1. Tecnologia da informação : Gestão de riscos 005.8

2. Empresas : Tecnologia da informação : Medidas de segurança 658.47

GESTÃO DE RISCOS EM AMBIENTES DE TI

Antônio Palmeira de Araújo Neto





Administração Regional do Senac no Estado de São Paulo

Presidente do Conselho Regional

Abram Szajman

Diretor do Departamento Regional

Luiz Francisco de A. Salgado

Superintendente Universitário e de Desenvolvimento

Luiz Carlos Dourado

Editora Senac São Paulo

Conselho Editorial

Luiz Francisco de A. Salgado

Luiz Carlos Dourado

Darcio Sayad Maia

Lucila Mara Sbrana Sciotti

Luís Américo Tousi Botelho

Gerente/Publisher

Luís Américo Tousi Botelho

Coordenação Editorial

Verônica Pirani de Oliveira

Prospecção

Andreza Fernandes dos Passos de Paula

Dolores Crisci Manzano

Paloma Marques Santos

Administrativo

Marina P. Alves

Comercial

Aldair Novais Pereira

Comunicação

Tania Mayumi Doyama Natal

Coordenação de Arte

Antonio Carlos De Angelis

Coordenação de Revisão de Texto

Marcelo Nardeli

Acompanhamento Pedagógico

Otacília da Paz Pereira

Designer Educacional

Fernanda Daniela Chaves Oliveira

Revisão Técnica

Monica Mancini

Preparação e Revisão de Texto

Amanda loost

Projeto Gráfico

Alexandre Lemes da Silva

Emília Corrêa Abreu

Capa

Antonio Carlos De Angelis

Editoração Eletrônica e Ilustrações

Leonardo Miyahara

Imagens

Adobe Stock Photos

Proibida a reprodução sem autorização expressa.
Todos os direitos desta edição reservados à

Editora Senac São Paulo
Av. Engenheiro Eusébio Stevaux, 823 – Prédio Editora
Jurubatuba – CEP 04696-000 – São Paulo – SP
Tel. (11) 2187 4450
editora@sp.senac.br
<https://www.editorasenacsp.com.br>

© Editora Senac São Paulo, 2025

Sumário

Capítulo 1 **Introdução à gestão de riscos em ambientes de TI, 7**

- 1 Ambientes de TI, 9
- Considerações finais, 22
- Referências, 23

Capítulo 2 **Avaliação de vulnerabilidades e identificação de riscos, 25**

- 1 A importância da identificação de riscos e vulnerabilidades em ambientes de TI, 26
- 2 Técnicas de avaliação e priorização de riscos, 31
- 3 Estabelecimento de políticas de gestão de riscos, 40
- Considerações finais, 41
- Referências, 42

Capítulo 3 **Políticas de privacidade e backup, 45**

- 1 Importância do backup e da privacidade de dados, 47
- 2 Planejamento de backup e recuperação, 55
- 3 Integração com a gestão de riscos, 59
- Considerações finais, 65
- Referências, 66

Capítulo 4 **Construção do plano de contingência, 69**

- 1 Introdução ao plano de contingência, 70
- Considerações finais, 85
- Referências, 86

Capítulo 5 **Segurança de perímetro para infraestruturas de TI, 87**

- 1 Conceitos de segurança de perímetro, 88
- Considerações finais, 103
- Referências, 104

Capítulo 6 **Monitoramento e mitigação de riscos em ambientes de TI, 107**

- 1 Riscos que podem afetar a imagem e o financeiro da empresa, 108
- Considerações finais, 121
- Referências, 122

Capítulo 7 **Planejamento e execução de políticas de tolerância ao risco, 125**

- 1 Conceitos de tolerância ao risco, 126
- Considerações finais, 138
- Referências, 139

Capítulo 8 **Infraestrutura de data centers, 141**

- 1 Fundamentos da infraestrutura de data centers, 142
- Considerações finais, 156
- Referências, 157

Sobre o autor, 159

Introdução à gestão de riscos em ambientes de TI

A gestão de riscos em ambientes de tecnologia da informação (TI) é, hoje, uma das prioridades estratégicas das organizações, independentemente de seu porte ou setor de atuação. Em um cenário em que os dados se tornaram ativos valiosos e o funcionamento dos sistemas de informação (SI) depende fortemente da disponibilidade e da integridade das infraestruturas tecnológicas, o conhecimento sobre riscos e ameaças torna-se indispensável para quem atua ou pretende atuar na área de TI.

Neste capítulo, vamos abordar os conceitos iniciais da gestão de riscos aplicados especificamente aos ambientes tecnológicos. Parte-se da compreensão acerca da noção de risco, de suas classificações e da crescente importância de seu gerenciamento nos ambientes corporativos. O objetivo é estimular uma percepção crítica sobre os diversos tipos de riscos, como ataques cibernéticos e falhas físicas, ambientais e humanas, que podem comprometer seriamente o funcionamento e a credibilidade de uma organização.

Além disso, serão apresentadas as principais características da infraestrutura de TI, incluindo servidores, redes e a evolução para modelos baseados em computação em nuvem. A partir desse conhecimento, será possível compreender como os diferentes ambientes exigem abordagens específicas para análise e controle dos riscos, considerando suas vulnerabilidades e complexidades operacionais.

Em relação aos tipos de ameaças que podem afetar um ambiente de TI, que vão desde invasões físicas e digitais até eventos imprevisíveis, como falhas humanas ou desastres naturais, cada situação requer ações de prevenção e resposta adequadas, portanto serão discutidas com base em boas práticas e normas internacionais atualizadas.

Por fim, o capítulo traz uma introdução ao conceito de segurança da informação, com foco nos princípios da confidencialidade, integridade e disponibilidade. Esses pilares, amplamente reconhecidos por normas vigentes de segurança da informação, ajudam a estabelecer critérios para a proteção das informações em todas as suas formas, assegurando o cumprimento de requisitos legais, regulatórios e contratuais.

Ao concluir este capítulo, espera-se que o leitor compreenda a importância da gestão de riscos como um processo contínuo e multidisciplinar, que envolve a área técnica e se relaciona com a cultura organizacional, a estratégia do negócio e a responsabilidade compartilhada pela segurança e continuidade dos serviços de TI.

1 Ambientes de TI

Ambientes de TI referem-se ao conjunto de recursos tecnológicos utilizados pelas organizações para processar, armazenar, proteger e transmitir dados. Esses ambientes podem incluir desde estruturas físicas, como servidores, redes cabeadas ou sem fio, dispositivos de armazenamento, data centers, até soluções virtuais, como sistemas de computação em nuvem, máquinas virtuais e plataformas baseadas na web (Varela, 2020).

Com o avanço das tecnologias digitais, os ambientes de TI se tornaram cada vez mais complexos e distribuídos, integrando diversas camadas de sistemas e dispositivos que operam de forma simultânea e interdependente. Essa diversidade ampliou o alcance dos serviços prestados, mas também deixou mais latente o número de vulnerabilidades e pontos de falha possíveis.

É justamente nesse contexto que a gestão de riscos em TI ganha relevância. Quanto mais heterogêneo e conectado é o ambiente, maior a exposição a ameaças que podem comprometer o desempenho, a segurança da informação e a continuidade das operações. Compreender o funcionamento desses ambientes é o primeiro passo para identificar riscos e adotar medidas que garantam sua resiliência.

1.1 Conceitos de gestão de riscos

A gestão de riscos é uma prática que busca antecipar, avaliar e lidar com incertezas que possam comprometer os objetivos de uma organização. No contexto da TI, o risco está associado à possibilidade de que um evento (interno ou externo, acidental ou intencional) afete negativamente a integridade, a disponibilidade ou a confidencialidade dos sistemas e dados corporativos (Konopczyk, 2022).

Gerenciar riscos significa entender que a imprevisibilidade faz parte dos ambientes tecnológicos, e que a única forma eficaz de lidar com ela é a partir de uma abordagem sistemática. Isso envolve identificar os ativos críticos, reconhecer as ameaças potenciais, estimar as vulnerabilidades do ambiente e implementar mecanismos capazes de reduzir a probabilidade e o impacto de incidentes indesejados (Konopczyk, 2022).

Uma das primeiras etapas nesse processo é compreender o que se define como risco em TI. Em termos simples, risco é a possibilidade de algo sair diferente do esperado, e essa diferença pode significar tanto perdas operacionais quanto danos à reputação ou descumprimento de obrigações legais. Não se trata apenas de ataques externos, como vírus ou invasões, mas também de quedas de energia, falhas de equipamentos, erros humanos e até fenômenos naturais.

O objetivo da gestão de riscos não é eliminar todas as ameaças, mas tomar decisões com base em critérios técnicos sobre como lidar com elas da forma mais adequada. De forma integrada, essa gestão deve considerar: aspectos técnicos da segurança da informação e de cultura organizacional; o comportamento dos usuários; os processos de governança; e os requisitos normativos e frameworks de referência. Um dos modelos que orientam a gestão de riscos de forma mais ampla é a norma ABNT NBR ISO 31000 (2018).

No contexto corporativo, um risco mal administrado pode se concretizar em paralisações de serviços, vazamento de dados confidenciais, perda de produtividade ou até sanções legais. Por isso, a gestão de riscos deve estar integrada ao planejamento estratégico da empresa, envolvendo áreas técnicas e executivas na definição de prioridades, políticas de segurança e processos de resposta a incidentes.

1.1.1 O que é gestão de riscos e qual é sua relevância

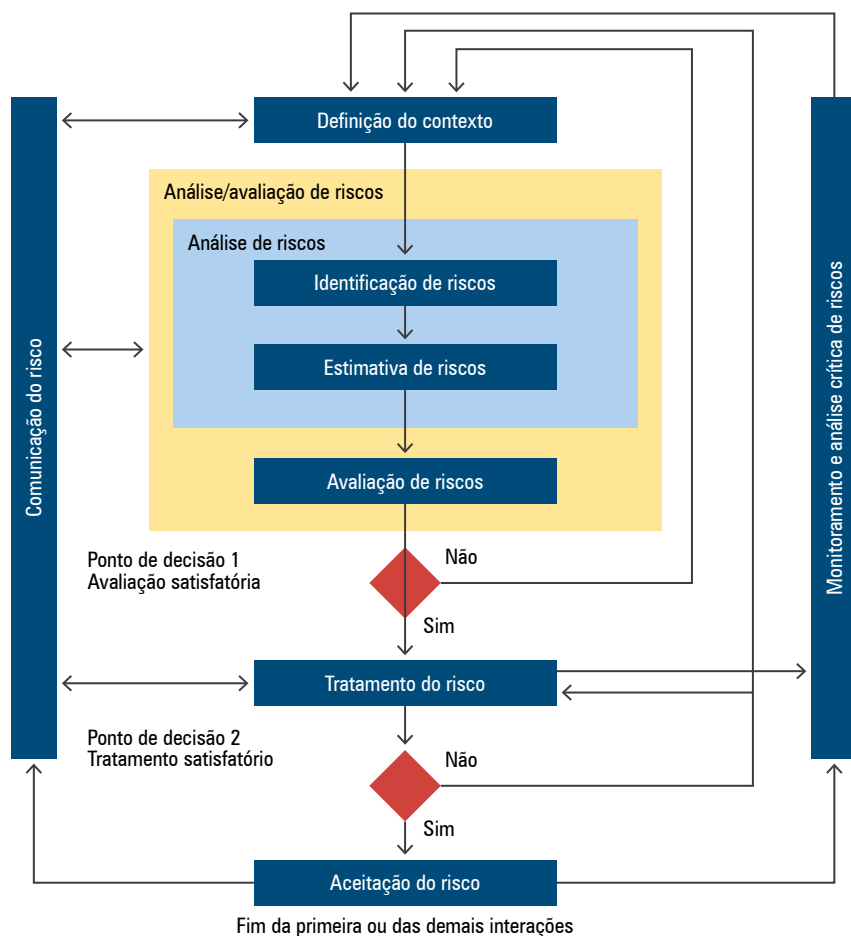
A gestão de riscos em TI pode ser compreendida como um processo estruturado que visa identificar, analisar, avaliar e tratar os riscos que possam comprometer os ativos digitais e a operação das organizações. Trata-se de uma prática estratégica, que permite antecipar ameaças e tomar decisões embasadas sobre como lidar com elas, de forma a minimizar prejuízos e evitar interrupções nos serviços da organização (Furtado, 2020).

A relevância da gestão de riscos está no fato de que ela promove a resiliência organizacional (capacidade que uma instituição tem de se adaptar e reagir de forma eficaz a mudanças, crises ou imprevistos). Em um ambiente cada vez mais digitalizado e conectado, ignorar ou subestimar os riscos pode levar a consequências graves. Como exemplo prático, podemos mencionar uma empresa que centraliza seu sistema de vendas em uma plataforma digital e não realiza análise de risco. Essa empresa pode ser surpreendida por uma falha de servidor em um fim de semana de alto volume de compras. A paralisação do sistema, ainda que temporária, pode resultar em perda de receita, insatisfação de clientes e desgaste da imagem da marca.

Nesse sentido, a gestão de riscos permite à organização responder aos eventos com mais agilidade, além de desenvolver ações preventivas e contingenciais. Assim, o mapeamento de riscos ajuda a estabelecer prioridades, alocar recursos de forma mais eficiente e fortalecer a segurança dos processos e das informações.

A figura 1, a seguir, apresenta o processo da gestão de riscos de segurança da informação.

Figura 1 – Processos da gestão de riscos da segurança da informação



Fonte: adaptado de ABNT (2019, p. 5).

1.1.2 Tipos de riscos: físicos, lógicos e ambientais

Os riscos podem ser classificados em três categorias principais: físicos, lógicos e ambientais. Cada uma apresenta características e impactos distintos sobre a operação dos sistemas e a segurança das informações (Pegetti, 2022).

Os riscos físicos referem-se a danos materiais que comprometem diretamente os equipamentos e a infraestrutura tecnológica. Exemplos comuns incluem furto de servidores, incêndios em data centers, quedas de energia e atos de vandalismo. Um servidor exposto em uma sala sem controle de acesso físico, por exemplo, pode ser facilmente violado ou danificado, colocando em risco dados sensíveis e operações críticas (Barreto *et al*, 2018).

Já os riscos lógicos estão ligados a falhas ou ataques que ocorrem no ambiente digital. Isso inclui invasões por malware, sequestro de dados (ransomware), acessos indevidos por meio de senhas fracas, falhas de software e vulnerabilidades exploradas por cibercriminosos. Tais riscos, embora invisíveis fisicamente, podem causar danos significativos, como a interrupção de sistemas ou a exposição de informações confidenciais (Barreto *et al*, 2018).

Por fim, os riscos ambientais são aqueles decorrentes de fenômenos naturais ou condições ambientais inadequadas. Enchentes, queda de raios, variações extremas de temperatura, umidade elevada e poeira em excesso podem afetar o funcionamento dos equipamentos e até inutilizá-los. Além disso, muitos desses eventos são imprevisíveis, o que exige a adoção de medidas preventivas como salas climatizadas, sistemas de detecção de fumaça e energia redundante (Barreto *et al*, 2018).



IMPORTANTE

Avaliando os riscos (principalmente a sua tipologia) estimamos a chance de um evento acontecer e compreendemos as possíveis consequências para os ativos de TI e para o negócio como um todo.

1.1.3 Impacto da falta de gestão de riscos em ambientes corporativos

A ausência de uma gestão de riscos estruturada em ambientes de TI pode acarretar uma série de consequências negativas para as organizações, tanto no aspecto técnico quanto no estratégico. Sem um processo contínuo de identificação, avaliação e tratamento de riscos, as empresas tornam-se vulneráveis a falhas que comprometem sua operação, sua imagem no mercado e até sua existência.

Um dos impactos mais imediatos da falta de gestão de riscos é a interrupção de serviços. Sistemas indisponíveis, ainda que por curtos períodos, podem causar prejuízos financeiros expressivos, perda de produtividade e insatisfação de clientes. Em setores críticos, como saúde, ou serviços públicos de forma geral, a indisponibilidade pode representar riscos à vida humana ou à segurança social.

Outro efeito recorrente é o vazamento de dados sensíveis, que pode acontecer em virtude de falhas técnicas, ausência de controle de acessos ou negligência na proteção das informações. Esse tipo de incidente gera impactos legais e regulatórios, especialmente diante de legislações como a Lei Geral de Proteção de Dados (LGPD) (Brasil, 2018), além de comprometer a confiança dos stakeholders (Barreto *et al.*, 2018).

A falta de gestão de riscos também contribui para o agravamento de falhas humanas. Equipes sem treinamento adequado ou sem protocolos definidos para lidar com incidentes estão mais propensas a tomar decisões equivocadas em momentos críticos, o que pode ampliar os danos causados por eventos adversos (Machado, 2014).

Além disso, a reputação da organização pode ser seriamente afetada. Em um mundo conectado, a divulgação de falhas de segurança ou incidentes de indisponibilidade rapidamente chega até o público, afetando a percepção de confiabilidade da marca e gerando reações negativas no

mercado. Pense, por exemplo, em uma instituição financeira que sofre uma pane em seus servidores justamente no dia do pagamento dos salários. A ausência de planos de contingência pode prolongar esta paralisação, resultando em perdas para os clientes, reclamações públicas e danos à credibilidade da instituição.

Como último impacto, é possível dizer que a ineficiência operacional também é um reflexo direto da ausência de gestão de riscos. Recursos podem ser mal alocados, controles aplicados de forma inadequada e decisões tomadas sem base em análises consistentes. Isso compromete a capacidade da organização de se antecipar a problemas e responder com agilidade em cenários adversos.

1.2 Contextualização de ambientes de TI

Os ambientes de TI, conforme abordado anteriormente, consistem no conjunto de recursos tecnológicos utilizados pelas organizações para executar suas atividades digitais, abrangendo desde elementos físicos até soluções virtuais. Em cada um desses ambientes, existe uma base estruturada que viabiliza o funcionamento adequado dos sistemas. Trata-se da infraestrutura de TI.

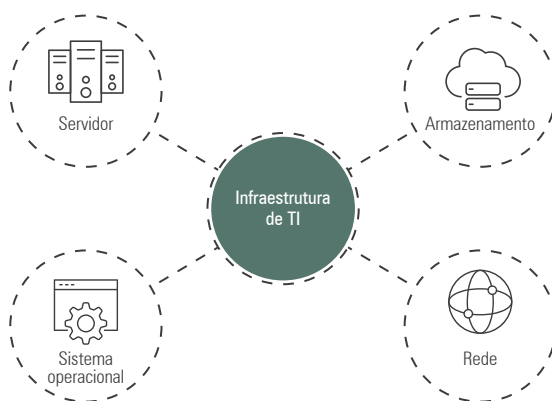
A infraestrutura de TI é o conjunto de componentes tecnológicos que formam a espinha dorsal dos sistemas computacionais corporativos. Ela é integrada por servidores, dispositivos de armazenamento, equipamentos de rede, sistemas operacionais, plataformas de virtualização, softwares de controle e ambientes de suporte. Sua função é assegurar que os dados sejam processados, armazenados, transmitidos e protegidos de maneira eficaz (Varela, 2020).

De acordo com Varela (2020), uma infraestrutura bem dimensionada precisa contemplar cinco pilares: o hardware (equipamentos físicos), o software (programas e sistemas operacionais), a rede (interligação de dispositivos), o armazenamento de dados (físico ou em nuvem) e os

serviços de suporte (monitoramento, segurança, backups). Esses componentes são organizados para atender às necessidades do negócio, promover desempenho, garantir disponibilidade e suportar o crescimento da organização.

A figura 2 apresenta uma visão geral dos principais elementos que compõem uma infraestrutura de TI típica.

Figura 2 – Componentes da infraestrutura de TI



Fonte: Varela (2020).

A compreensão da infraestrutura é indispensável para o cotidiano do gerenciamento de riscos. Afinal, a criticidade dos ativos depende da função que desempenham e do impacto que sua falha pode gerar. Por exemplo, a indisponibilidade de um servidor de autenticação pode comprometer o acesso a todos os sistemas da organização, enquanto uma falha em equipamentos de rede pode interromper operações distribuídas.

Além disso, o cenário atual é marcado pela descentralização da infraestrutura, com a adoção crescente de ambientes híbridos, que combinam data centers locais com recursos em nuvem. Essa flexibilidade traz ganhos operacionais, mas também amplia a superfície de exposição a

riscos, exigindo novos mecanismos de controle, governança e segurança (Barreto *et al.*, 2018).

1.2.1 Infraestrutura de TI: servidores, backbone e redes

Dentro da infraestrutura de TI há um grande destaque para os servidores, que podem estar localizados em data centers físicos ou em ambientes virtuais e em nuvem, conforme a arquitetura adotada. Eles são responsáveis pelo processamento e armazenamento de dados, além de hospedarem aplicações e controlarem acessos na rede de comunicação de dados (Varela, 2020).

Outro componente importante é o backbone. Ele é a estrutura principal de interconexão entre redes locais e externas, garantindo alta velocidade e estabilidade na transmissão de dados entre diferentes pontos da organização (Varela, 2020).

Complementando essa estrutura estão as redes de comunicação de dados responsáveis por conectar dispositivos e sistemas. Elas podem ser cabeadas ou sem fio e utilizam equipamentos como switches, roteadores, pontos de acesso, dentre outros. A eficiência e a segurança dessas redes são de grande importância para o funcionamento de todos os serviços digitais (Varela, 2020).

1.2.2 Diferenças e semelhanças entre TI tradicional e cloud computing

Nos dias de hoje, é possível perceber a TI estruturada de duas formas distintas: a TI tradicional, baseada em ativos físicos controlados internamente, e a TI em nuvem (cloud computing), fundamentada em recursos virtuais acessados remotamente por meio da internet. Ambas coexistem em muitas organizações e representam abordagens diferentes de entrega e gerenciamento de serviços tecnológicos.

A TI tradicional depende da aquisição, instalação e manutenção de equipamentos físicos, como servidores, *storages* e roteadores, que ficam sob responsabilidade da própria organização. Essa modalidade garante maior controle sobre os ativos e dados, mas exige investimentos significativos em infraestrutura, pessoal qualificado e atualizações constantes (Varela, 2020).

Em contrapartida, a computação em nuvem oferece recursos como armazenamento, processamento e aplicações sob demanda, através de provedores externos especializados. Nesse modelo, a organização contrata os serviços conforme sua necessidade, pagando proporcionalmente ao uso, o que permite maior escalabilidade e flexibilidade operacional (Araújo Neto, 2023).

Apesar das diferenças estruturais, os dois modelos compartilham preocupações comuns quanto à segurança da informação, disponibilidade dos serviços e conformidade com normas e legislações. No entanto, a forma como essas questões são gerenciadas muda significativamente. Na nuvem, parte das responsabilidades é transferida ao provedor, exigindo uma atenção redobrada na definição de contratos, no controle de acessos e na proteção de dados sensíveis (Araújo Neto, 2023).

Já na TI tradicional, toda a responsabilidade pela segurança recai sobre a própria organização, que deve implementar medidas técnicas e administrativas para proteger seus ativos físicos e digitais, o que inclui desde a configuração adequada de servidores até políticas internas de acesso e backup. Assim, enquanto a nuvem demanda uma gestão compartilhada da segurança, o modelo tradicional exige um controle integral e direto por parte da empresa (Araújo Neto, 2023).

1.3 Tipos de ameaças em ambientes de TI

Ambientes de TI estão constantemente expostos a ameaças que podem comprometer a continuidade das operações, a segurança dos

dados e a integridade dos sistemas. Essas ameaças assumem formas diversas (físicas, lógicas, humanas e naturais) e exigem estratégias específicas de prevenção e resposta (Konopczyk, 2022).

1.3.1 Invasões: físicas e lógicas

As invasões físicas ocorrem quando uma pessoa não autorizada acessa instalações como salas de servidores ou racks de rede. Um exemplo é o acesso de um visitante não identificado a uma sala técnica sem supervisão, podendo conectar dispositivos maliciosos à rede.

Já as invasões lógicas envolvem ações realizadas por meio da rede, como ataques via malware ou exploração de senhas fracas. Um exemplo é o uso de *phishing* para obter credenciais de acesso administrativo ao sistema interno da empresa.

1.3.2 Prevenção de invasão

A prevenção exige medidas físicas e digitais. No ambiente físico, pode-se utilizar leitores biométricos ou câmeras de segurança. Em um exemplo prático, uma empresa pode bloquear automaticamente a porta de acesso ao datacenter caso um visitante não seja autenticado. Na camada lógica, técnicas como firewall, criptografia e autenticação multifator são essenciais. Imagine uma organização que impede o acesso remoto aos seus sistemas sem VPN e autenticação em dois fatores — isso reduz drasticamente o risco de invasões externas

1.3.3 Intempéries naturais e desastres tecnológicos

Esses eventos afetam diretamente a infraestrutura de TI. Podemos citar como exemplo de intempérie natural uma enchente que invade o prédio corporativo e danifica os servidores por falta de elevação adequada. Já um desastre tecnológico pode ser exemplificado por uma pane

elétrica que desliga inesperadamente o data center por ausência de um sistema de nobreak ou gerador. Em ambos os casos, os prejuízos podem ser graves, exigindo medidas de redundância e contingência (Pegetti, 2022).

1.3.4 Impactos de falhas humanas e de sistemas

Erros humanos continuam sendo uma das maiores causas de falhas em TI. Um analista de suporte que acidentalmente deleta arquivos de configuração de rede, derrubando o acesso à internet corporativa, é um exemplo de falha humana.

As falhas de sistemas, por sua vez, podem ocorrer por bugs em atualizações não testadas. Um sistema ERP que para de funcionar após uma atualização malsucedida pode interromper atividades financeiras e logísticas da empresa (Machado, 2014).

1.4 A importância da segurança da informação

Em ambientes de TI, a segurança da informação é essencial para proteger dados, sistemas e ativos contra acessos não autorizados, alterações indevidas ou perdas. Com a crescente dependência de recursos digitais, garantir que as informações estejam seguras tornou-se um aspecto estratégico para a continuidade dos negócios. Essa segurança deve ser pensada desde o planejamento da infraestrutura até o uso cotidiano por parte dos usuários (Pegetti, 2022).

Além da proteção operacional, a segurança da informação tem impacto direto na reputação das organizações e na sua conformidade com leis e regulamentações. Investir em boas práticas reduz riscos e aumenta a resiliência frente a incidentes diversos, como falhas técnicas, ataques cibernéticos ou erros humanos (Barreto et al., 2018).

1.4.1 Garantia de confidencialidade, integridade e disponibilidade

Segundo Machado (2014), confiabilidade, integridade e disponibilidade são os três princípios que formam a base da segurança da informação.

- Confidencialidade diz respeito ao acesso restrito à informação. Por exemplo, relatórios financeiros de uma empresa só devem ser acessados por pessoas autorizadas. Um caso prático seria o uso de criptografia para proteger dados armazenados em dispositivos móveis corporativos.
- Integridade refere-se à precisão e consistência dos dados. Uma alteração indevida em um contrato digital pode gerar prejuízos jurídicos. Por isso, sistemas com controle de versões e auditoria são adotados para assegurar que os dados permaneçam inalterados sem autorização (Konopczyk, 2022).
- Disponibilidade garante que a informação esteja acessível quando necessário. Imagine uma clínica médica que dependa de um sistema eletrônico para atender pacientes; a indisponibilidade do sistema prejudica diretamente o atendimento e pode comprometer a segurança dos pacientes.

Juntos, esses princípios (também chamados de tríade CID) orientam políticas, controles e práticas no campo da segurança da informação (Machado, 2014).

1.4.2 Conformidade com normas e regulamentações

A conformidade legal é outro pilar crítico da segurança da informação. Diversas normas, como a ABNT NBR ISO/IEC 27001, e leis nacionais, como a Lei Geral de Proteção de Dados (LGPD) (Brasil, 2018), exigem que as organizações adotem medidas específicas para proteger dados e garantir direitos dos titulares.

Por exemplo, uma empresa que coleta dados pessoais em sua loja virtual deve obter consentimento explícito do usuário, garantir a segurança dessas informações e possibilitar a exclusão quando solicitada. O descumprimento pode acarretar multas e danos à imagem institucional (Machado, 2014).

Além da LGPD (Brasil, 2018), setores como o financeiro e o da saúde estão sujeitos a regras específicas. No setor bancário, o Banco Central impõe exigências relacionadas à segurança digital e continuidade de negócios.

A adoção de frameworks e normas reconhecidas facilita a demonstração de conformidade e orienta processos internos mais seguros, promovendo uma cultura organizacional voltada à proteção da informação.

Considerações finais

Ao longo deste capítulo, foi possível compreender como a gestão de riscos em ambientes de TI contribui diretamente para a estabilidade e o sucesso das operações organizacionais.

Foram discutidos os fundamentos da gestão de riscos, seus conceitos, importância e tipos, destacando como a ausência de uma abordagem estruturada pode comprometer desde a operação dos sistemas até a reputação institucional. Também foram apresentados os principais elementos que compõem os ambientes de TI, com ênfase na infraestrutura tecnológica e suas especificidades, incluindo servidores, redes e soluções em nuvem.

Também foram abordados o papel das ameaças e a necessidade de adotar mecanismos preventivos e de resposta que garantam a continuidade das operações. A segurança da informação foi discutida a partir dos pilares da confidencialidade, integridade e disponibilidade, destacando a importância de estar em conformidade com as normas e as regulamentações, como a ABNT NBR ISO/IEC 27001 e a LGPD (Brasil, 2018).

A partir das discussões apresentadas, conclui-se, portanto, que gerir riscos em TI envolve implementação de ferramentas tecnológicas, decisões estratégicas, além da integração entre setores e uma cultura organizacional voltada à prevenção, à proteção e à responsabilidade compartilhada.

Referências

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS (ABNT). **ABNT NBR ISO/IEC 27005:2019**: tecnologia da informação: técnicas de segurança: gestão de riscos de segurança da informação. 3. ed. Rio de Janeiro: ABNT, 2019.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS (ABNT). **ABNT NBR ISO 31000:2018** – Gestão de riscos – Diretrizes. Rio de Janeiro, 2018.

ARAÚJO NETO, A. P. **Arquitetura de data center**. São Paulo: Editora Senac São Paulo, 2023.

BARRETO, J. S.; ZANIN, A.; MORAIS, I. S.; VETTORAZZO, A. S. **Fundamentos de segurança da informação**. Porto Alegre: Sagah, 2018.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). **Diário Oficial da União**: seção 1, Brasília, DF, ano 156, n. 157, p. 59-64, 15 ago. 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 14 ago. 2025.

FURTADO, L. L. **Gestão de riscos**. Curitiba: Contentus, 2020.

IKONOPCZYK, M. G. **Riscos, auditoria e resposta a incidentes**. São Paulo: Editora Senac São Paulo, 2022.

MACHADO, F. N. R. **Segurança da informação**: princípios e controle de ameaças. São Paulo: Érica, 2014.

PEGETTI, A. **Gestão da segurança da informação**. São Paulo: Editora Senac São Paulo, 2022.

VARELA, W. A. **Infraestrutura de TI**. São Paulo: Editora Senac São Paulo, 2020.

